

Report Finale

Analisi Comparativa tra Nmap e Nessus Essentials

Obiettivo

Lo scopo dell'attività è stato quello di confrontare due tra i più diffusi strumenti di analisi della sicurezza:

- **Nmap** (Network Mapper)
- **Nessus Essentials**

Entrambi sono stati utilizzati per analizzare la macchina **Metasploitable 2 (192.168.50.21)**.

Sebbene abbiano lo stesso obiettivo generale, il loro approccio è completamente differente.

Nmap Scan Report - Scanned at Thu Jul 9 08:03:12 2026

Scan Summary | 192.168.50.21

Scan Summary

Nmap 7.99 was initiated at Thu Jul 9 08:03:12 2026 with these arguments:
/usr/lib/nmap/nmap -A -p--T4 -oA scan_metasploitable 192.168.50.21

Verbosity: 0; Debug level 0

Nmap done at Thu Jul 9 08:05:48 2026; 1 IP address (1 host up) scanned in 156.89 seconds

192.168.50.21

Address

- 192.168.50.21 (IPv4)
- 08:00:27:8D:AD:11 - Oracle VirtualBox virtual NIC (mac)

Ports

The 65505 ports scanned but not shown below are in state: **closed**

- 65505 ports replied with: **reset**

Port	State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4
	ftp-syst	STAT: FTP server status: Connected to 192.168.50.20 Logged in as ftp TYPE: ASCII No session bandwidth limit Session timeout in seconds is 300 Control connection is plain text Data connections will be plain text vsFTPd 2.3.4 - secure, fast, stable End of status				
	ftp-anon	Anonymous FTP login allowed (FTP code 230)				
22	tcp	open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1 protocol 2.0
	ssh-hostkey	1824 60:0f:cfe:1c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA) 2048 56:56:24:0f:121:1d:de:a7:12b:ae:61:b1:24:3d:e8:f3 (RSA)				
99	tcp	open	telnet	syn-ack	telnet	

Go to top

Toggle Closed Ports

Toggle Filtered Ports

25	tcp	open	smtp	syn-ack	Postfix smtpd		
	ssl-date	2026-07-09T12:05:44+00:00; -4s from scanner time.					
	smtp-commands	metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN					
	ssl-cert	Subject: commonName=ubuntu004-base.localdomain/organizationName=OC05A/stateOrProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2010-03-17T14:07:45 Not valid after: 2010-04-16T14:07:45					
	sslv2	SSLv2 supported ciphers: SSL2_RC2_128_CBC_EXPORT40_MD5 SSL2_RC4_128_MD5 SSL2_DES_64_CBC_MD5 SSL2_RC4_128_EXPORT40_MD5 SSL2_DES_192_EDE3_CBC_MD5 SSL2_RC2_128_CBC_MD5					
53	tcp	open	domain	syn-ack	TSC BIND	9.4.2	
	dns-nsid	bind.version: 9.4.2					
80	tcp	open	http	syn-ack	Apache httpd	2.2.8	(Ubuntu) DAV/2
	http-title	/metasploitable2 - Linux					
	http-server-header	Apache/2.2.8 (Ubuntu) DAV/2					
111	tcp	open	rpcbind	syn-ack		2	RPC #100000
	rpcinfo	program version port/proto service 100000 2 111/tcp rpcbind 100000 2 111/udp rpcbind 100003 2,3,4 2049/tcp nfs 100003 2,3,4 2049/udp nfs 100005 1,2,3 4096/tcp mountd 100005 1,2,3 54148/udp mountd 100021 1,3,4 37201/tcp nlockmgr 100021 1,3,4 58506/udp nlockmgr 100024 1 49044/udp status 100024 1 58515/tcp status					
139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.0.20-Debian	workgroup: WORKGROUP
512	tcp	open	exec	syn-ack	netkit-rsh rexecd		
513	tcp	open	login	syn-ack	OpenBSD or Solaris rlogind		
514	tcp	open	shell	syn-ack	Netkit rshd		
1099	tcp	open	java-rmi	syn-ack	GNU Classpath grmiregistry		
1574	tcp	open	honeyshell	syn-ack	Metasploitable root shell		

Go to top
Toggle Closed Ports
Toggle Filtered Ports

1. Analisi effettuata con Nmap

È stata eseguita una scansione completa tramite:

nmap -A -p- -T4 192.168.50.21

La scansione comprende:

- scansione di tutte le porte TCP
- rilevamento sistema operativo
- rilevamento versioni dei servizi
- esecuzione degli script NSE
- traceroute

La scansione è terminata in circa **157 secondi**.

Porte individuate

Nmap ha rilevato **30 porte TCP aperte**, tra cui:

Porta	Servizio	Versione
21	FTP	vsFTPD 2.3.4

22	SSH	OpenSSH 4.7
23	Telnet	Linux Telnet
25	SMTP	Postfix
53	DNS	BIND 9.4.2
80	HTTP	Apache 2.2.8
111	RPCBind	RPC
139	NetBIOS	Samba
445	SMB	Samba 3.0.20
512	rexec	Netkit
513	rlogin	OpenBSD
514	rsh	Netkit
1099	Java RMI	GNU Classpath
1524	Bind Shell	Root Shell
2049	NFS	RPC
2121	FTP	ProFTPD
3306	MySQL	5.0.51
3632	DistCC	4.2.4
5432	PostgreSQL	8.3
5900	VNC	Protocol 3.3
6000	X11	X Server
6667	IRC	UnrealIRCd
6697	IRC SSL	UnrealIRCd
8009	AJP13	Apache JServ
8180	Apache Tomcat	5.5
8787	Ruby DRb	Ruby 1.8

Le restanti porte appartengono ai servizi RPC di NFS.

Informazioni raccolte da Nmap

Oltre alle porte aperte, Nmap ha individuato:

- Sistema operativo Linux 2.6.x (accuratezza 100%)
- Nome host: metasploitable
- Dominio: metasploitable.localdomain
- SMB Signing disabilitato
- Login FTP anonimo consentito
- Supporto SSLv2
- Certificati SSL scaduti
- Banner completi dei servizi
- Versioni dettagliate dei software

Queste informazioni costituiscono un'importante fase di **ricognizione (Enumeration)**.

Vulnerabilità osservabili con Nmap

Pur non essendo un vulnerability scanner, Nmap permette comunque di individuare numerosi problemi:

FTP anonimo

Anonymous FTP Login Allowed

Consente l'accesso senza autenticazione.

vsFTPd 2.3.4

Versione nota per contenere una backdoor.

Telnet

Protocollo completamente non cifrato.

Samba 3.0.20

Versione estremamente obsoleta.

SSLv2

Protocollo crittografico ormai deprecato.

Certificati SSL scaduti

Rilevati durante gli script NSE.

Bind Shell

La porta **1524** ospita direttamente una shell root.

È uno degli indicatori di compromissione più gravi.

SMB Signing disabilitato

Favorisce attacchi di tipo Man in the Middle.

Versioni obsolete

Sono stati identificati software molto datati:

- Apache 2.2.8
 - MySQL 5.0
 - PostgreSQL 8.3
 - OpenSSH 4.7
 - BIND 9.4
 - Tomcat 5.5
-

Punti di forza di Nmap

- ✓ estremamente veloce
 - ✓ molto leggero
 - ✓ enorme quantità di script NSE
 - ✓ identifica servizi e versioni
 - ✓ ideale nella fase di reconnaissance
 - ✓ completamente gratuito
 - ✓ altamente personalizzabile
-

Limiti di Nmap

- ✗ non assegna automaticamente un livello di rischio
 - ✗ non produce remediation
 - ✗ richiede esperienza
 - ✗ individua i servizi ma non sempre stabilisce se siano realmente vulnerabili
-

2. Analisi effettuata con Nessus Essentials

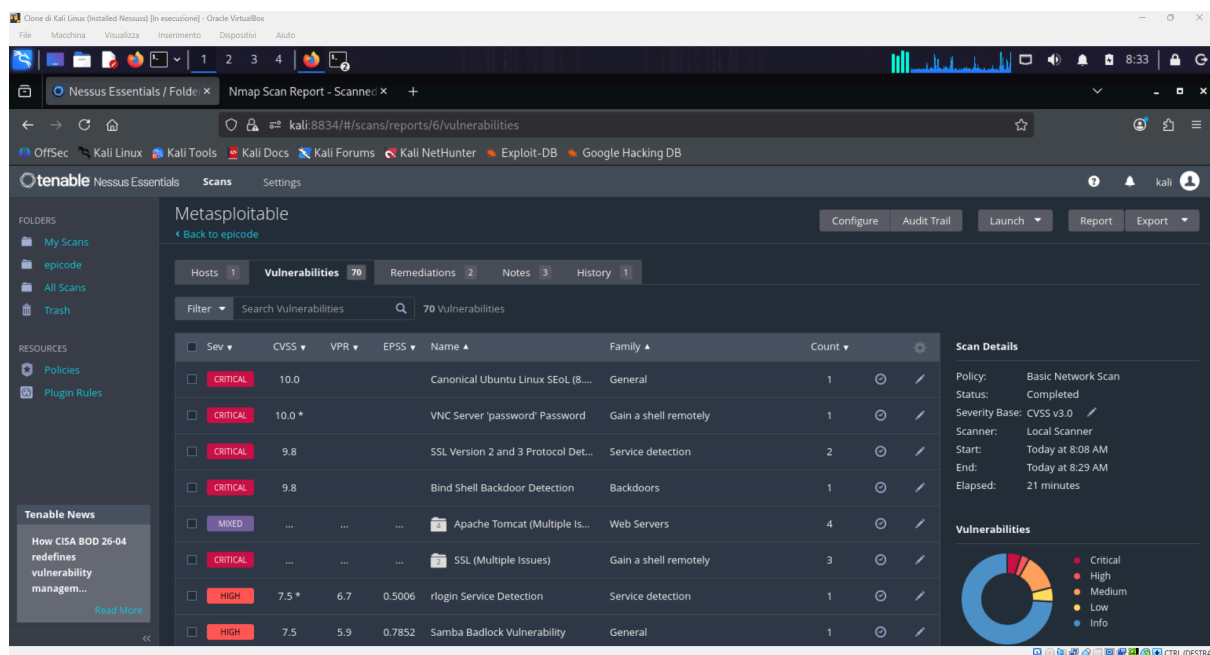
Nessus ha eseguito una scansione **Basic Network Scan**.

Durata:

- circa **21 minuti**

Sono state individuate:

70 vulnerabilità complessive



Principali vulnerabilità rilevate

Dallo screenshot risultano immediatamente evidenti:

Canonical Ubuntu Linux SEoL

CVSS 10.0

Sistema operativo fuori supporto.

VNC Server Password

CVSS 10

Password VNC debole.

Può consentire accesso remoto.

SSL Version 2 and 3 Detection

CVSS 9.8

Uso di protocolli crittografici obsoleti.

Bind Shell Detection

CVSS 9.8

Presenza di una shell remota.

Rischio massimo.

Apache Tomcat Multiple Issues

Diverse vulnerabilità note.

SSL Multiple Issues

Numerose vulnerabilità SSL.

rlogin Service

Protocollo insicuro.

Samba Badlock

Storica vulnerabilità Samba.

Dal report risultano inoltre:

- 70 vulnerabilità totali
 - remediation disponibili
 - classificazione CVSS
 - EPSS
 - VPR
 - categoria della vulnerabilità
 - famiglia del plugin
-

Punti di forza di Nessus

- ✓ individua vulnerabilità reali
 - ✓ assegna punteggi CVSS
 - ✓ calcola VPR
 - ✓ calcola EPSS
 - ✓ suggerisce remediation
 - ✓ database aggiornato
 - ✓ report professionali
 - ✓ molto semplice da utilizzare
-

Limiti di Nessus

- ✗ scansioni più lente
- ✗ maggiore consumo di risorse
- ✗ versione gratuita limitata
- ✗ non è pensato per l'enumerazione dettagliata come Nmap

Differenze principali

Nmap

Risponde alla domanda:

"Che cosa è presente sulla macchina?"

Fornisce informazioni su:

- porte
- servizi

- versioni
- sistema operativo
- banner
- enumerazione

È lo strumento ideale nella fase iniziale di un penetration test.

Nessus

Risponde invece alla domanda:

"Quali vulnerabilità presenta la macchina?"

Analizza:

- CVE note
 - configurazioni errate
 - protocolli insicuri
 - software obsoleti
 - criticità
 - priorità di intervento
-

Considerazioni finali

L'analisi dimostra come **Nmap e Nessus non siano strumenti concorrenti, ma complementari.**

Nmap eccelle nella fase di ricognizione, offrendo una mappatura dettagliata dell'infrastruttura e dei servizi esposti. Nessus, invece, sfrutta tali informazioni per eseguire un'analisi approfondita delle vulnerabilità, assegnando un livello di rischio (CVSS, VPR ed EPSS) e proponendo indicazioni di mitigazione.

Nel caso di **Metasploitable 2**, Nmap ha identificato un elevato numero di servizi obsoleti e configurazioni insicure (ad esempio FTP anonimo, Telnet, SMB, VNC e la bind shell sulla porta 1524), mentre Nessus ha classificato **70 vulnerabilità**, molte delle quali con severità **Critical** (CVSS fino a 10.0), confermando che il sistema è intenzionalmente vulnerabile e rappresenta un ambiente ideale per esercitazioni di penetration testing.

Conclusione: in un'attività di sicurezza reale è buona pratica utilizzare **prima Nmap** per l'enumerazione e la raccolta delle informazioni, quindi **Nessus** per la valutazione del rischio e la prioritizzazione delle vulnerabilità. L'utilizzo combinato dei due strumenti consente di ottenere una visione completa dello stato di sicurezza dell'host analizzato.

